Module 10: Linux Exploitation and Privilege Escalation

```
# Exercise 07: Identifying and Exploiting GNU Screen 4.5.0 for Local Privilege Escalation
```

Scenario

GNU Screen 4.5.0 SUID Local Privilege Escalation exploits a vulnerability in GNU Screen version 4.5.0 (CVE-2017-5618) caused by improper logfile creation handling (`-l` / `-L` options) combined with elevated SUID owner privileges (`/usr/bin/screen-4.5.0`). Because the SUID binary allows arbitrary file opening and logging without dropping root privileges, an attacker can append crafted shared library load instructions into `/etc/ld.so.preload` or write root password entries into `/etc/passwd`.

Key technical concepts in GNU Screen 4.5.0 privilege escalation:
1. **LinPEAS SUID Binary Identification**: Running **./linpeas.sh** on target system to discover unknown/suspicious SUID binaries, flagging **/usr/bin/screen-4.5.0** under *SUID - Check easy privesc, exploits and write perms*.
2. **Searchsploit Vulnerability Query**: Executing **searchsploit screen 4.5.0** to identify local privilege escalation exploit PoCs in Exploit-DB (`41154.sh`).
3. **Exploit-DB & PoC Script Review**: Auditing the PoC shell script structure, which compiles a C shared library (`libaction.so`) and appends `/etc/ld.so.preload` to execute root payload commands upon launching `screen-4.5.0`.
4. **Root Privilege Escalation Execution**: Granting permissions (**chmod 755 ./screenroot.sh**), executing **./screenroot.sh**, and spawning an unauthenticated root subshell (**whoami** $\rightarrow$ `root`).

In this exercise, we log into **Ubuntu** VM (**ubuntu** / **toor**), run `linpeas.sh`, detect **/usr/bin/screen-4.5.0**, query Searchsploit, review Exploit-DB entry, execute `./screenroot.sh`, and verify root privilege escalation (`whoami`).

Objective

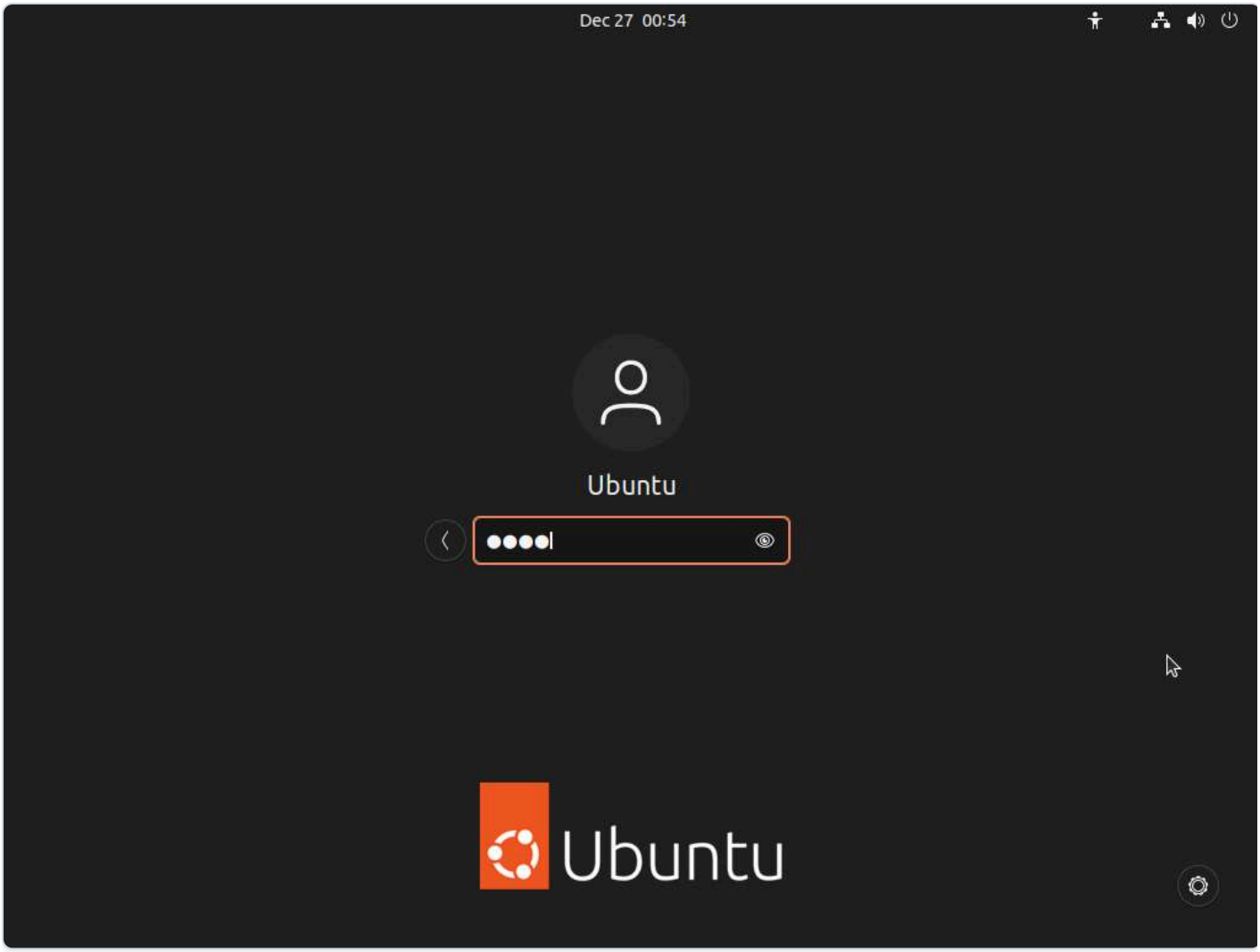
The objective of this lab is to help students learn how to:
- Authenticate to Ubuntu VM (**ubuntu** / **toor**)
- Execute LinPEAS audit to locate suspicious SUID binaries: **./linpeas.sh**
- Identify vulnerable GNU Screen binary: **/usr/bin/screen-4.5.0**
- Search local exploit database for screen 4.5.0 exploits: **searchsploit screen 4.5.0**
- Research CVE-2017-5618 exploit mechanism on Exploit-DB
- Grant execution permissions to PoC script: **chmod 755 ./screenroot.sh**
- Run privilege escalation script: **./screenroot.sh**
- Verify active root user shell access: **whoami**

Task 1: Enumerate System with LinPEAS, Identify Screen 4.5.0 SUID Binary, Execute Screenroot PoC, and Verify Root Shell Access

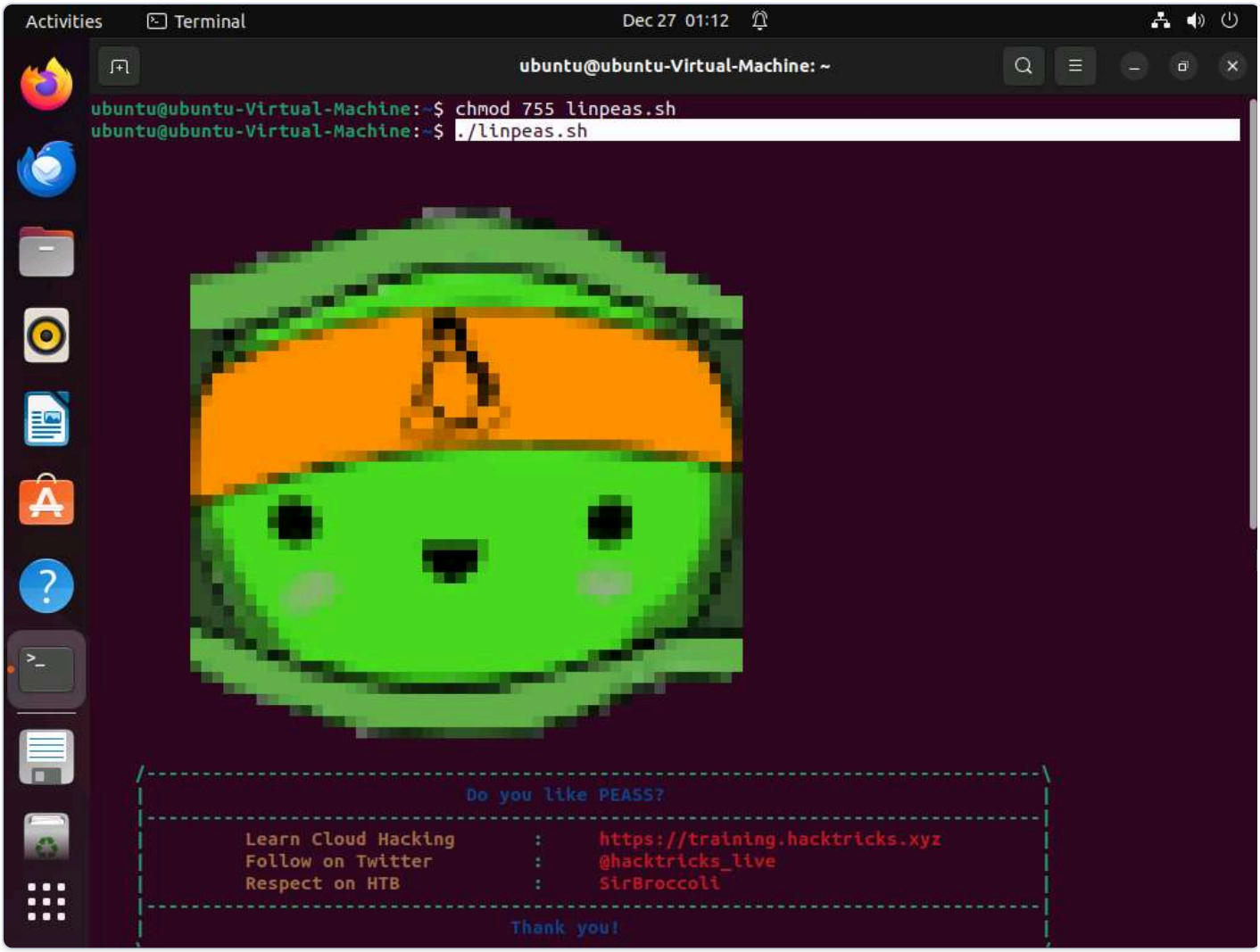
In this task, we run LinPEAS, locate `/usr/bin/screen-4.5.0`, query Searchsploit, execute `./screenroot.sh`, and verify root access.

Lab Tasks

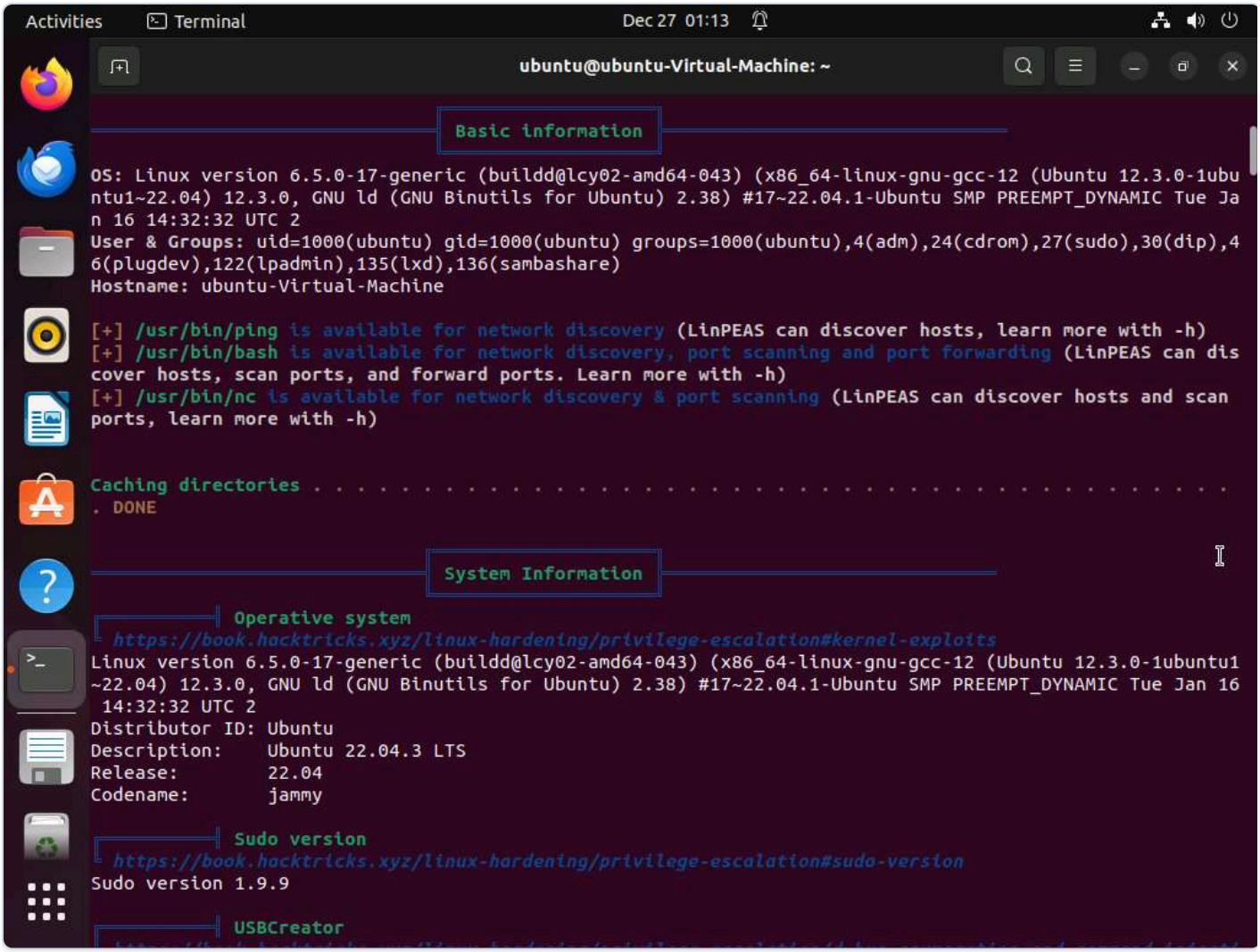
1. Log into **Ubuntu** VM using credentials (**ubuntu** / **toor**).



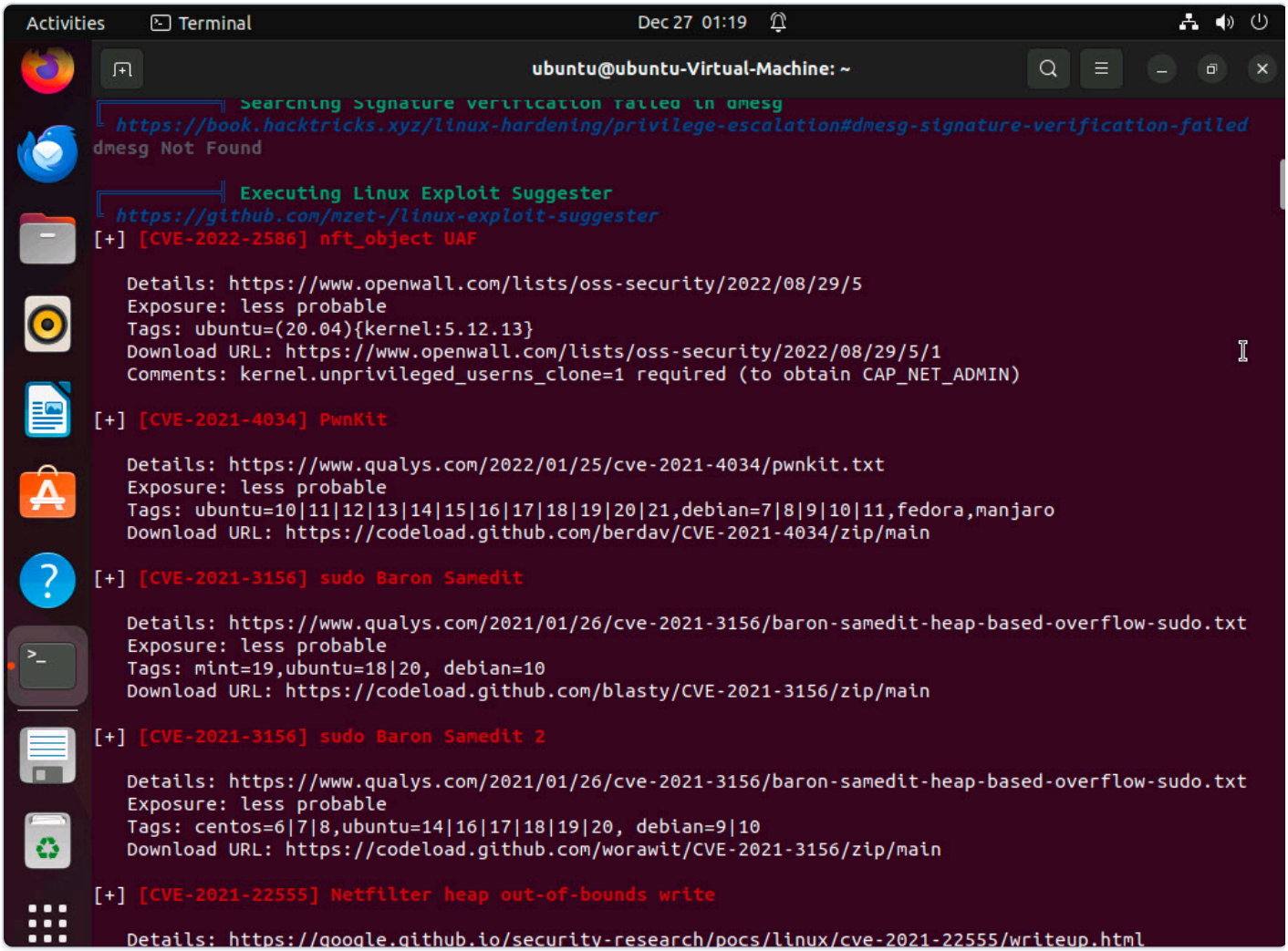
1. Open terminal window, set permissions, and run LinPEAS:
   chmod 755 linpeas.sh && ./linpeas.sh



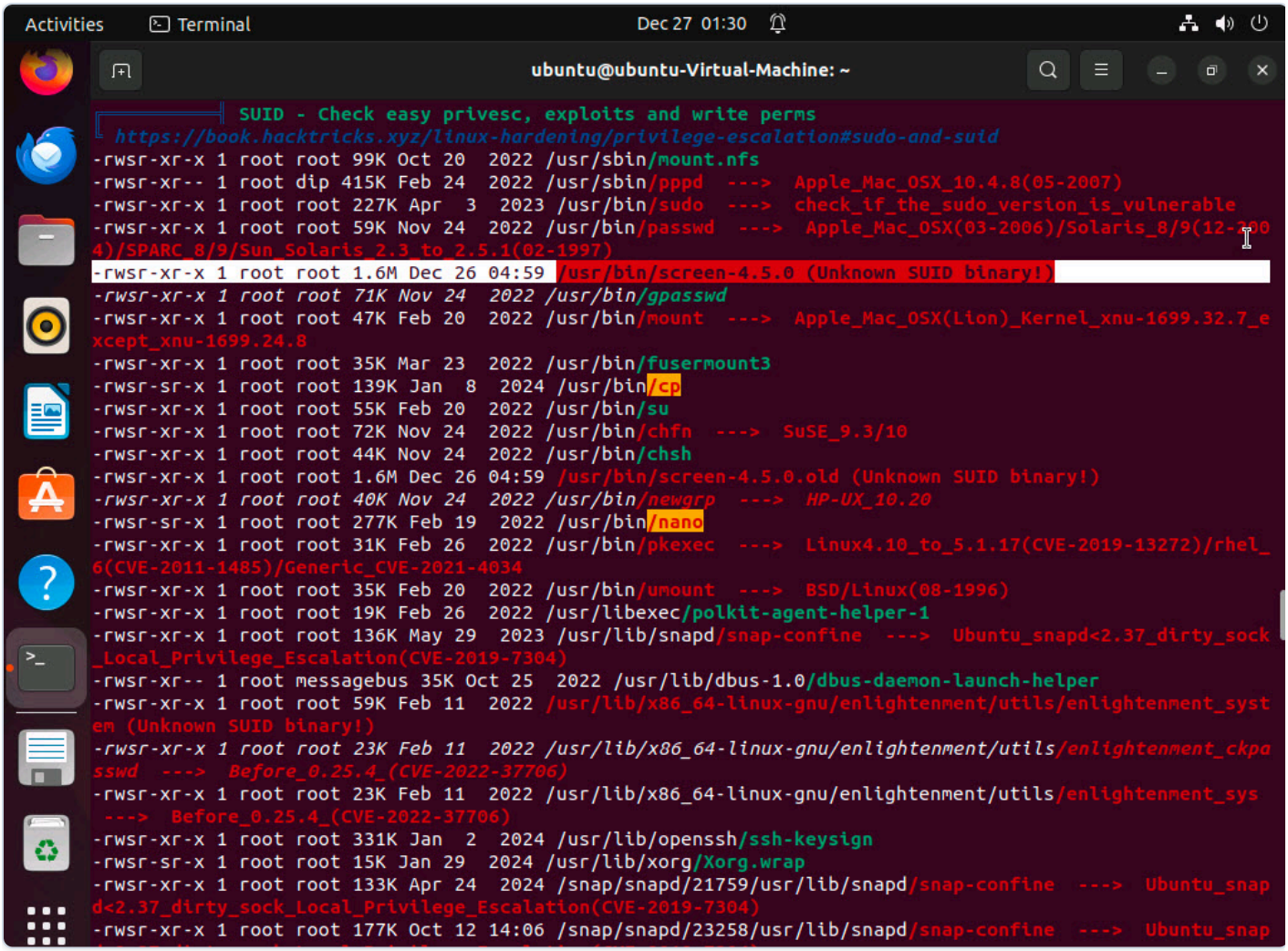
1. Scroll through LinPEAS system output to review operating system and kernel release.



1. Audit Linux Exploit Suggester section to view potential kernel exploit suggestions.

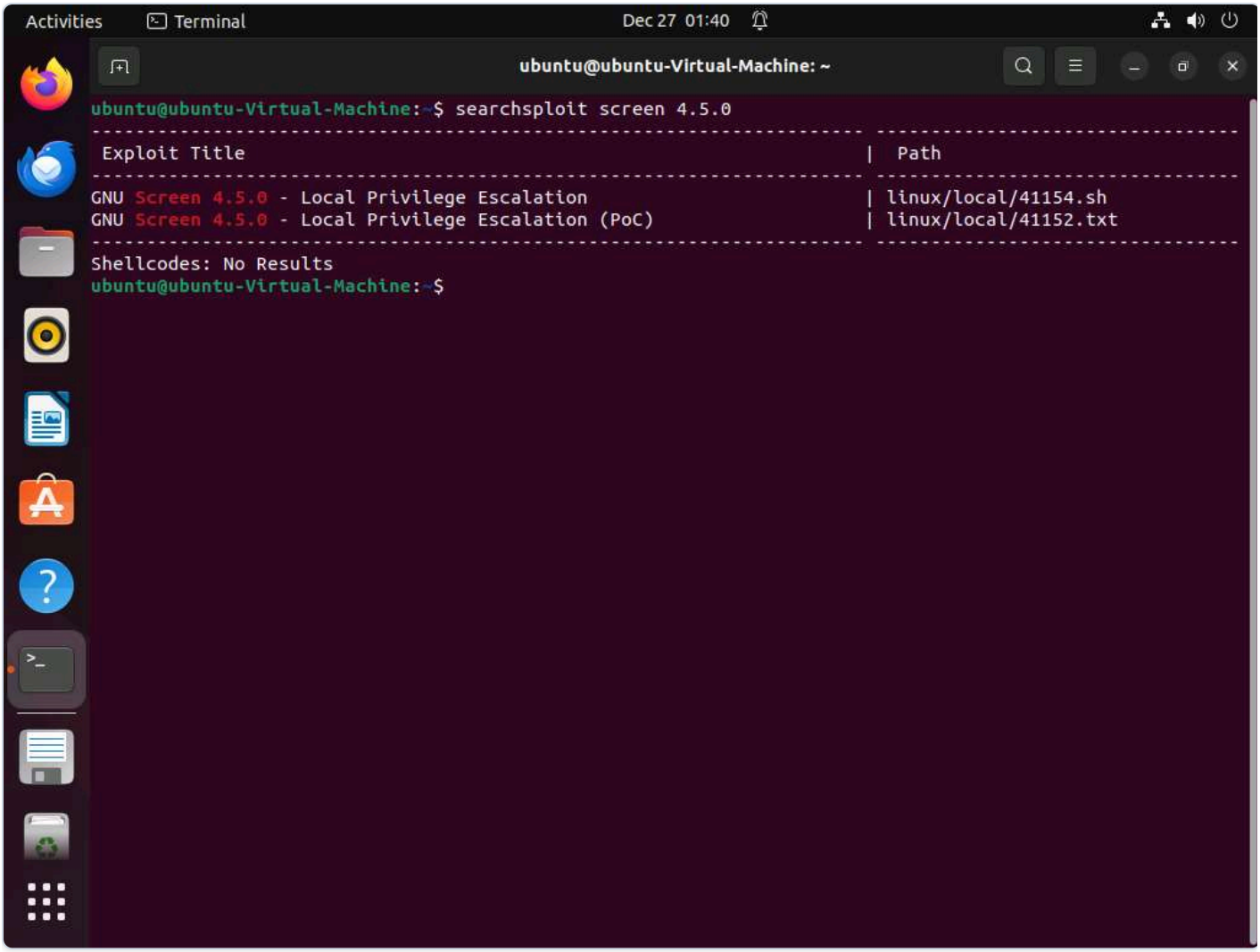


1. Locate SUID section (*SUID - Check easy privesc, exploits and write perms*) and identify flagged binary **/usr/bin/screen-4.5.0**.

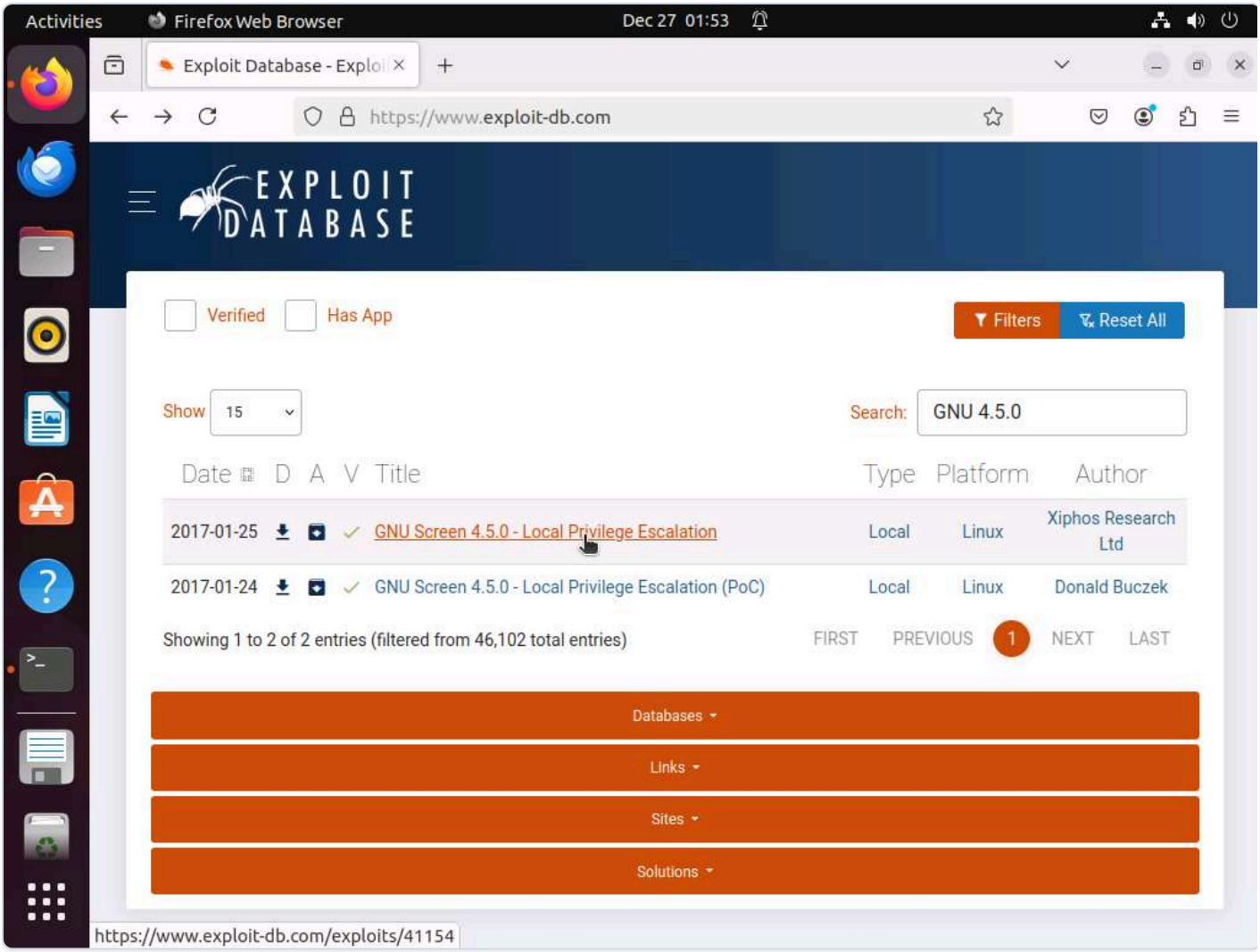


1. Query local exploit database for GNU Screen 4.5.0 exploits:

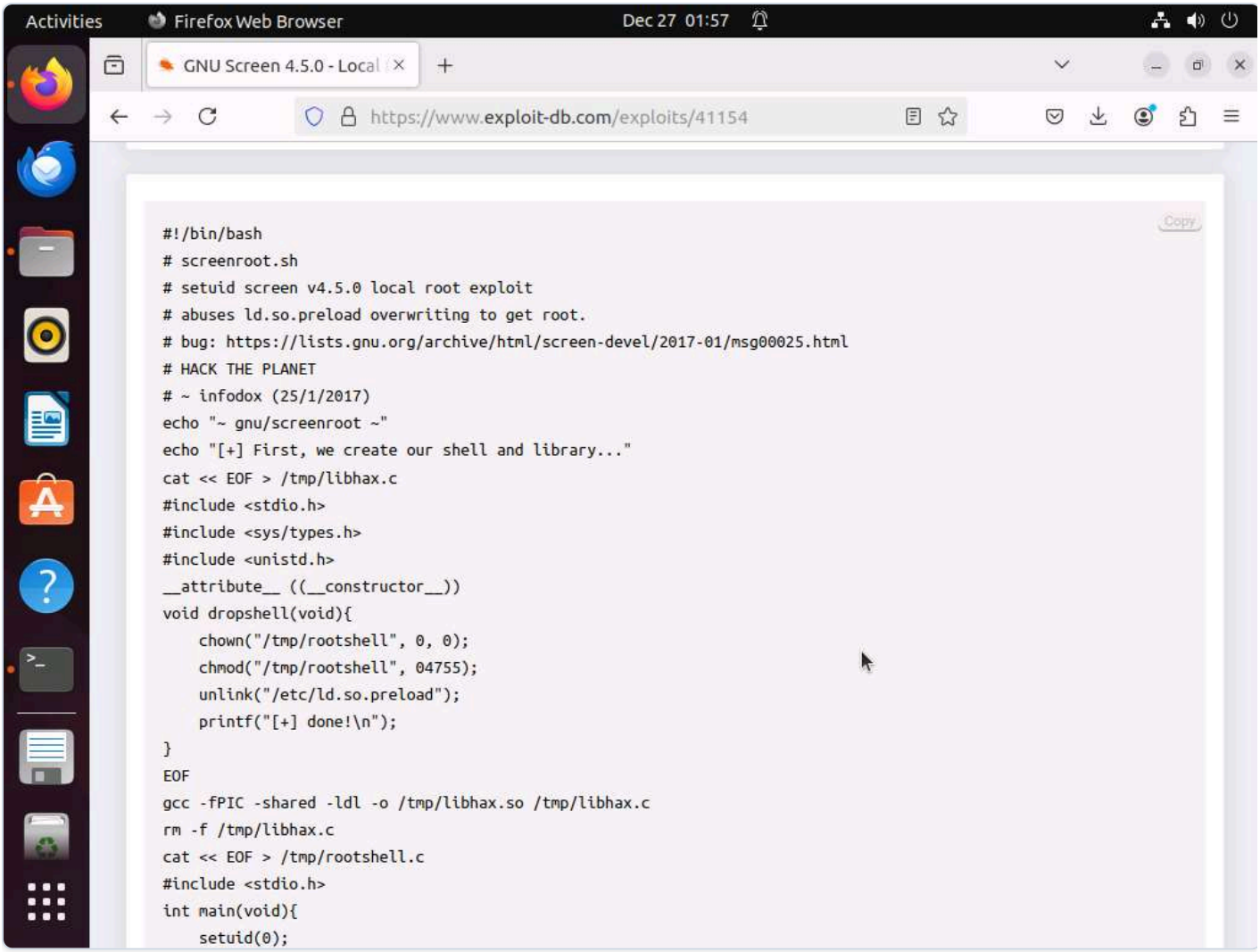
   searchsploit screen 4.5.0



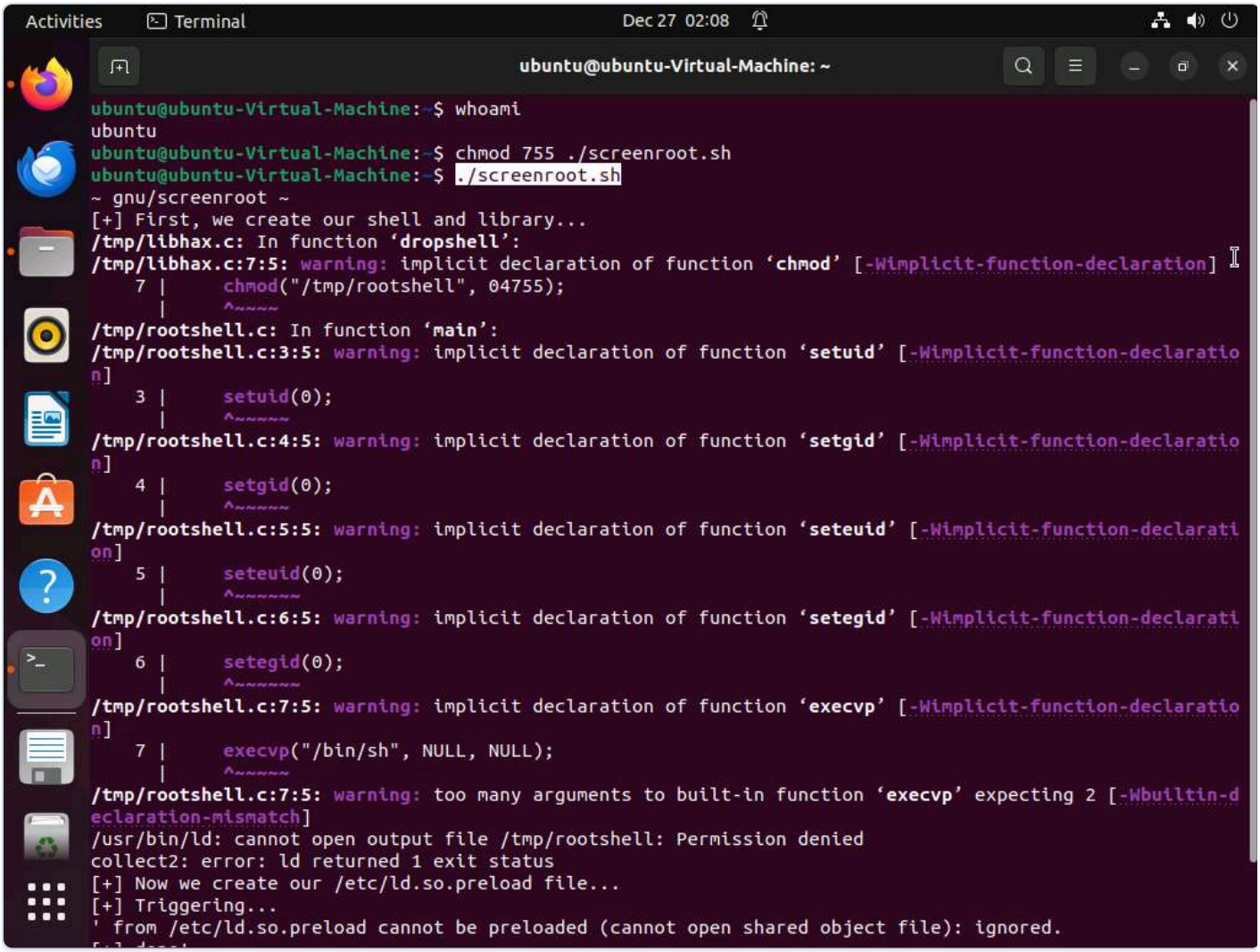
1. Open Firefox web browser and navigate to Exploit-DB (`https://www.exploit-db.com/`). Search for `GNU screen 4.5.0` .



1. Review exploit details and source code structure.



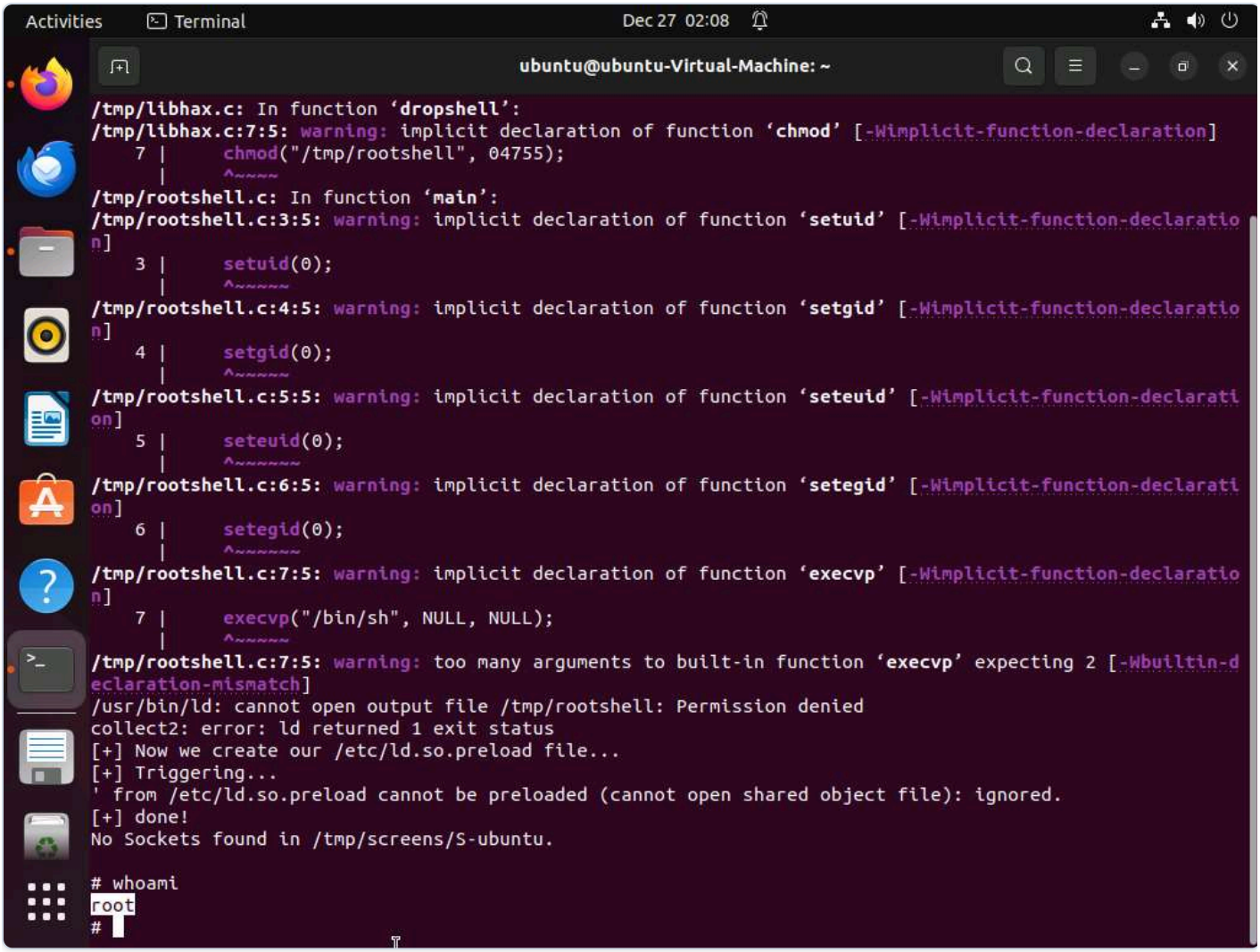
1. Minimize browser, open terminal, verify user identity (**whoami**), grant permissions, and run pre-placed PoC script:
   chmod 755 ./screenroot.sh
   ./screenroot.sh



1. Verify root shell spawned by `screenroot.sh`:

   whoami

   Observe output: `root` access achieved.



This concludes the lab exercise.

IMPORTANT: ❓ **Question 10.7.1.1** On an Ubuntu system, identify and exploit a local privilege escalation vulnerability in GNU Screen version 4.5.0. Utilize LinPEAS to enumerate the system and detect vulnerable services and binaries. Locate the GNU Screen 4.5.0 binary that was exploited in this lab. [!SUCCESS] ✅ **Answer:** **/usr/bin/screen-4.5.0**